

Name: Abraham Abebe

Course: Cybersecurity

Date: July 29, 2026

Title: Social Engineering Toolkit
(SET) and Reconnaissance

Exercise 6: Integrated Attack Scenario Report

Simulated Social Engineering Assessment of Fictional Target "FinanceCorp"

Target Organization: FinanceCorp (*Fictional*)

Assessment Type: Simulated Social Engineering Assessment

Environment: Isolated Kali Linux Virtual Machine

Tools Used: Maltego, GoPhish, Firefox Browser

Note: All names, domains, email addresses, and organizations referenced in this report are fictional and were created solely for educational purposes. No real individuals, systems, or organizations were targeted.

Executive Summary

This exercise simulated a phishing assessment against a fictional organization, **FinanceCorp**, to demonstrate the complete social engineering attack lifecycle. The assessment included reconnaissance using **Maltego**, development of a phishing pretext, and deployment of a simulated phishing campaign using **GoPhish**. The campaign targeted fictional employees and was conducted entirely within an isolated laboratory environment. The objective was to understand how attackers gather information, create convincing phishing emails, and capture user credentials while identifying security controls that can prevent or reduce the effectiveness of such attacks.

1. Reconnaissance Findings

1.1 Organization Profile

The fictional organization used in this exercise was **FinanceCorp**, with the fictional internal domain **financecorp.local**.

Three fictional employees were identified for the assessment.

1.2 Information Gathered

Maltego was used to build a relationship graph showing the information that an attacker could gather before launching a phishing campaign.

The following information was identified:

```
[abrish@archlinux sherlock]$ ls
bio2.txt      email3.txt      organization2.txt  roles.txt         unique_urls.txt   usernames3.txt
bio.txt       found_accounts.txt organization3.txt  social_media2.txt unique_usernames.txt usernames.txt
domains2.txt  found.txt       organization.txt   social_media3.txt url2.txt
domains3.txt  hierarchy3.txt  results          social_media.txt  url3.txt
domains.txt   names2.txt     results.txt      target2.txt       urls.txt
email1.txt    names3.txt     roles2.txt       target3.txt       url.txt
email2.txt    names.txt      roles3.txt       target3.txt       usernames2.txt
[abrish@archlinux sherlock]$ _
```

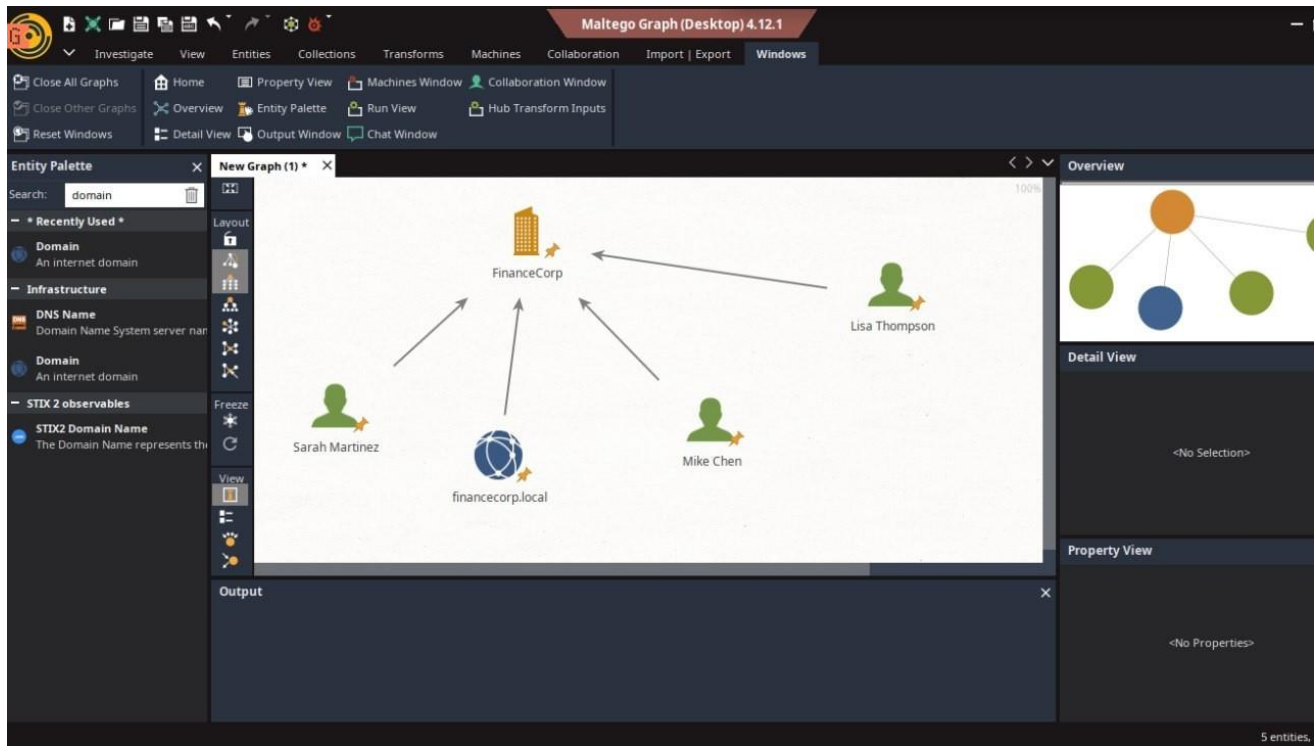
I get this information from sherlock using saved .txt files

Employee Name	Job Role	Email Address
Mike Chen	Software Engineer / React Evangelist	mike.chen@financecorp.local
Sarah Martinez	Senior Data Scientist	sarah.martinez@financecorp.local
Lisa Thompson	Graphic Designer	lisa.thompson@financecorp.local
Mark Chen	Photographer (Taiwan)	mark.chen@financecorp.local

Although no real social media accounts were investigated, the exercise demonstrated how publicly available information can be combined to identify potential phishing targets and improve the realism of

an attack.

The Maltego graph illustrated how a single domain can be expanded into multiple entities such as employees, email addresses, and organizational relationships.



1.3 Target Selection

Among the fictional employees, **Lisa Thompson**, the HR Manager, was selected as the primary phishing target.

HR staff regularly receive emails regarding employee records, account updates, and internal announcements. Because password reset notifications are common, an urgent email appearing to come from the IT department is more likely to appear legitimate.

By comparison, the IT Administrator would likely recognize common phishing indicators due to greater technical knowledge and security awareness.

2. Attack Methodology

2.1 Phishing Pretext

The phishing campaign used the following pretext:

IT Department Password Reset Notification

The email informed recipients that they needed to reset their password immediately because of an important security update.

The phishing email relied on three common social engineering techniques:

- **Authority** – The message appeared to come from the IT department.
- **Urgency** – Immediate action was requested.
- **Familiarity** – Password reset emails are common in many organizations.

These elements made the phishing email appear more realistic and convincing.

2.2 Attack Process

The simulated attack followed six main stages.

Step 1 – Reconnaissance

Information about FinanceCorp was collected using Maltego. Employee names, job roles, and the assumed email format were documented.

Step 2 – Intelligence Documentation

The collected information was organized to create realistic employee profiles for the phishing campaign.

Step 3 – Phishing Preparation

A phishing email template was created in GoPhish.

Email Subject

Urgent: Security Update Required for Your Account

The email included a phishing link using the GoPhish variable:

<https://mail.google.com/mail>

Step 4 – Landing Page Creation

A phishing landing page was created to resemble an internal password reset page.

The following GoPhish options were enabled

These settings allowed GoPhish to record submitted credentials during the simulation.

Step 5 – Campaign Deployment

A GoPhish campaign was created using:

- Email Template
- Landing Page
- Target Group
- Sending Profile

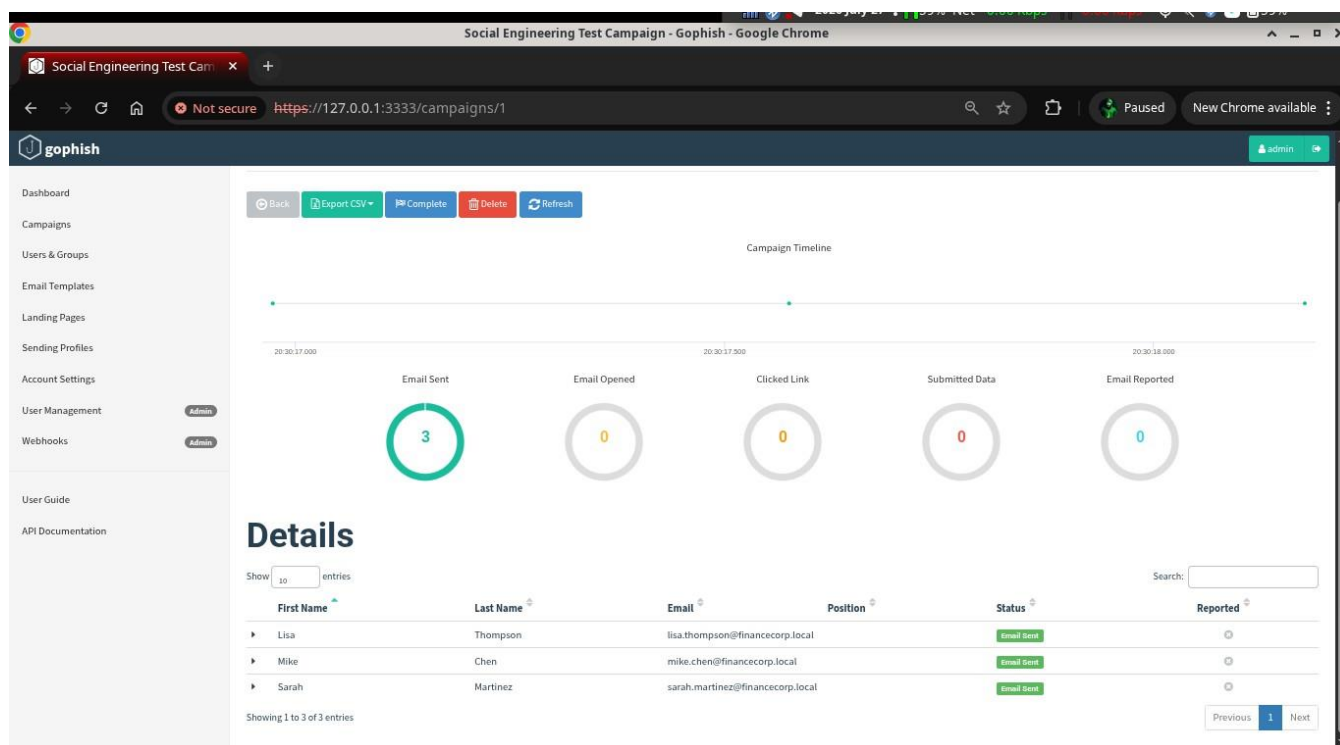
The campaign targeted the three fictional FinanceCorp employees and was launched from the GoPhish dashboard.

Step 6 – Credential Capture

To simulate user interaction, the phishing link was opened manually.

Test credentials were entered into the phishing page and submitted.

GoPhish successfully recorded the submitted username and password, demonstrating that the simulated credential-harvesting process worked correctly.



3. Campaign Results

Since this exercise was performed in a controlled laboratory environment rather than with real users, the results were evaluated qualitatively.

Campaign Stage	Result
Email Sent	Simulated Successfully
Email Opened	Simulated
Link Clicked	Successful
Landing Page Loaded	Successful
Test Credentials Submitted	Successful
Credentials Captured	Successful

The successful capture of the submitted credentials confirmed that the phishing infrastructure functioned as intended.

In a real phishing awareness campaign, organizations would typically measure:

- Email delivery rate
- Email open rate
- Click-through rate
- Credential submission rate

- Phishing reporting rate

Among these metrics, the **phishing reporting rate** is considered the most valuable because it measures how many employees recognize and report suspicious emails instead of interacting with them.

4. Defensive Countermeasures

Several security measures can reduce the likelihood and impact of phishing attacks.

4.1 Limiting Reconnaissance

Organizations should:

- Limit employee information published on public websites.
- Restrict access to organizational charts.
- Avoid publicly exposing email naming conventions.
- Monitor for excessive information gathering and web scraping.

4.2 Preventing Phishing Emails

Email security can be improved by implementing:

- SPF (Sender Policy Framework)
- DKIM (DomainKeys Identified Mail)
- DMARC (Domain-based Message Authentication, Reporting, and Conformance)
- Secure email gateways
- URL filtering
- Attachment sandboxing

These controls help identify and block spoofed or malicious emails before they reach users.

4.3 Protecting User Credentials

Organizations should also implement:

- Multi-Factor Authentication (MFA)
- Strong password policies
- Password managers
- Login monitoring and anomaly detection

Password managers provide an additional layer of protection because they do not automatically fill credentials on fake websites.

4.4 User Awareness and Incident Response

Technology alone cannot stop every phishing attack. Organizations should also:

- Conduct regular security awareness training.
- Perform periodic phishing simulations.
- Teach employees how to recognize phishing emails.
- Encourage users to verify urgent requests through trusted communication channels.
- Provide an easy and blame-free method for reporting suspicious emails.

A strong reporting culture helps security teams respond quickly and reduce the impact of phishing attacks.

5. Conclusion

This exercise successfully demonstrated the complete lifecycle of a simulated phishing attack, beginning with reconnaissance and ending with credential capture. Maltego was used to collect and organize information about a fictional organization, while GoPhish was used to create and launch a simulated phishing campaign that successfully captured test credentials within a controlled laboratory environment.

The exercise showed that phishing attacks rely on both technical methods and human behavior. Technical controls such as SPF, DKIM, DMARC, and Multi-Factor Authentication (MFA) are important, but they are most effective when combined with regular security awareness training and a strong incident reporting process.

Finally, all GoPhish campaigns, landing pages, and captured test credentials were removed after the exercise in accordance with the laboratory cleanup procedures, ensuring that no testing infrastructure or data remained active after the lab was completed.